# Cross-reference-only revision notice

**v1.0-RC3** | 11 September 2026 | SOURCE-OF-TRUTH SYNCHRONIZATION ONLY

| Control | Selected value |
|---|---|
| **Revision** | v1.0-RC2 -> **v1.0-RC3** |
| **Semantic change** | **NONE.** This revision changes source version/count/path references only. |
| **Wave-2 semantic authorities** | DOC-07 RC2 \| DOC-08 RC2 \| DOC-15 RC8 \| DOC-16 RC5 |
| **Canonical HTTP companion** | contracts/http/BLOG-DOC-15_openapi_v1.0-RC8.yaml |
| **OpenAPI SHA-256** | bf577a463b4c5d8fdceddc2087f53216426ef88d67d8e1a0d22ccf819751cd00 |
| **RC8 estate** | 113 operations \| 86 paths \| 221 schemas/helpers \| 1,311 resolved internal refs \| 0 unresolved refs<br>12 AUTH \| 2 PUBLIC/PREVIEW \| 63 SITE \| 36 GLOBAL |

## DOCUMENT-SPECIFIC SYNCHRONIZATION

• Security transport references now consume DOC-15 v1.0-RC8. The canonical AUTH family is API15-AUTH-001..012 (12 AUTH operations).

• API15-AUTH-012 GET /api/v1/auth/selectable-sites is an authenticated current-session projection. DOC-19 continues to own credential/session/MFA/security mechanics; DOC-02 and DOC-04 continue to own authorization, assignments and trusted SiteContext. The selector response grants no authority.

• Discovery cross-reference is DOC-16 v1.0-RC5. All inherited assertions that say exactly 11 AUTH operations or DOC-15 RC7 are historical/superseded cross-references only.

## SUPERSESSION AND HISTORICAL CLASSIFICATION

The inherited body that follows is retained unchanged in substantive page content. Any inherited non-owning reference to DOC-15 RC7/RC6, the old 112/85/217/1,297 estate, 11 AUTH operations, DOC-16 RC4, or the RC7 YAML filename is classified **HISTORICAL / SUPERSEDED REFERENCE** and is not normative in this revision. All other inherited owned semantics remain in force.

Occurrence ledger: RC7/old HTTP: inherited printed pages 1, 2, 4, 5, 8, 14, 24, 25, 28, 29, 30, 36; RC4: inherited printed pages 1, 24.

**IMPLEMENTATION IMPACT: NONE. The accepted NAKSHATRA_MASTER_WAVE2_HANDOFF application/database/API behavior is unchanged by this document synchronization.**

BLOG-DOC-19

# Security, Authentication, Sessions, Audit, Privacy, Secrets & Recovery Specification

Developer execution authority for credential security, Admin/Preview trust, session lifecycle, step-up, browser protections, immutable audit semantics, privacy minimization, secrets and security recovery across the centralized 14-site platform

| 14 | 69 | 3 | 1 |
|---|---|---|---|
| site identities | fixed permissions | account states | designated Super Admin |

**CORE SECURITY PRINCIPLE**

Authentication establishes who the caller is; authorization still comes from DOC-02 and trusted SiteContext still comes from DOC-04. A valid session, MFA proof, Preview grant, cookie, token, IP address, browser state or secret never substitutes for current account state, assignment, permission, target ownership, lifecycle and server-side validation.

| Document control | Value |
|---|---|
| Status | REVIEW CANDIDATE - DOC-15 RC7 reconciliation complete; technically freeze-ready pending approval |
| Version | 1.0-RC2 |
| Date | 10 September 2026 |
| Frozen upstream authorities | BLOG-DOC-01 through BLOG-DOC-14; BLOG-DOC-15 v1.0-RC7 + OpenAPI; BLOG-DOC-16 v1.0-RC4; BLOG-DOC-17 v1.0-RC2; BLOG-DOC-18 v1.0-RC2 |
| Primary authority | Credential/password/MFA mechanics; session and Preview authority lifecycle; CSRF/CORS/security headers; security throttling; secret management; step-up/reauthentication; audit event dictionary/privacy rules; incident and security recovery. |
| Explicit non-authority | Product scope/features/permissions (01-03); SiteContext/RLS model (04/08); page/flow estate (05/06/10/11); content lifecycle (07); HTTP endpoint method/path/schema/status contract (15); SEO/search/sitemap (16); media transform/CDN semantics (17); queue/cache mechanics (18); capacity/RPO/RTO topology (20); exhaustive QA implementation (21); code/deployment choices (23/24). |

## Developer lock target

A competent developer must not have to guess password hashing parameters, invitation/reset/MFA semantics, session idle/absolute expiry, logout/revocation, CSRF proof, allowed CORS behavior, Preview credential handling, step-up strength/window, security headers, credential-store boundaries, secret rotation, audit event codes,

privacy-safe audit detail, security incident containment or recovery ordering. DOC-15 RC7 supplies the canonical authentication/security HTTP access surfaces; DOC-19 owns their security mechanics and must not redefine their methods, paths, schemas or statuses.

# 0. Document Map


| Section | Subject |
|---|---|
| 1 | Purpose, authority, conflict rule and upstream reconciliation |
| 2 | Frozen security invariants from DOC-01 through DOC-18 |
| 3 | Security architecture, trust zones and stores |
| 4 | Admin identity and credential binding |
| 5 | Password policy and Argon2id verifier |
| 6 | Login and authentication state machine |
| 7 | Invitation, password setup and activation |
| 8 | Password change and password reset |
| 9 | MFA enrollment, verification and recovery |
| 10 | Admin session contract, cookies and expiry |
| 11 | Session revocation and authorization freshness |
| 12 | Step-up / reauthentication for high-risk actions |
| 13 | Preview handoff and private Preview authority |
| 14 | CSRF protection |
| 15 | CORS and origin enforcement |
| 16 | Security headers, TLS and browser isolation |
| 17 | Security rate limiting and abuse controls |
| 18 | Input validation, output encoding and injection safety |
| 19 | Media/upload security overlay |
| 20 | Secrets, service credentials and key rotation |
| 21 | Security-state persistence boundary |
| 22 | Audit architecture and event dictionary |
| 23 | Audit detail, immutability and privacy minimization |
| 24 | Privacy, consent and retention policy |
| 25 | Destructive-action security matrix |
| 26 | Admin/public/worker security boundaries |
| 27 | Incident classification and containment |
| 28 | Credential/account/security recovery runbooks |

| Section | Subject |
|---|---|
| 29 | Security logging, metrics and alert signals |
| 30 | Threat and failure semantics |
| 31 | End-to-end execution examples |
| 32 | Cross-document consistency audit |
| 33 | Traceability registry |
| 34 | Comprehensive acceptance criteria |
| 35 | Dependencies, downstream handoff and freeze readiness |
| A | Authentication/token/session matrix |
| B | Canonical audit event-code registry |
| C | High-risk/step-up matrix |
| D | Security header and browser-control baseline |
| E | One-page developer execution reference |

**AUTHORITY BOUNDARY**

DOC-19 may choose security mechanics explicitly delegated by DOC-02/DOC-15/DOC-18, but it may not add a permission, feature, Admin Page ID, HTTP operation, database table/column, content state, media variant, job type or tenant context. If an HTTP security action requires a method/path/schema not present in DOC-15, DOC-19 defines the security behavior and records a controlled DOC-15 dependency.

# 1. Purpose, Authority, Conflict Rule and Upstream Reconciliation

## 1.1 Purpose

BLOG-DOC-19 converts the security responsibilities deliberately deferred by earlier documents into one deterministic implementation contract. It secures the single Central Admin, private Preview handoff, shared backend/API, site-scoped workers and public applications without weakening the frozen authorization, SiteContext, RLS, API, media or queue contracts.

## 1.2 One source of truth per security decision

| Decision | Authority |
|---|---|
| Account states, roles, permissions, prerequisites, privilege ceiling | DOC-02 |
| Trusted CTX-ADMIN-SITE / CTX-WORKER-SITE / CTX-GLOBAL / CTX-PREVIEW-SITE | DOC-04 |
| Admin page/action confirmations and state behavior | DOC-10 |
| Post destructive/publishing state legality | DOC-07 |

| Decision | Authority |
|---|---|
| Audit-event physical row shape and append-only DB rule | DOC-08 |
| HTTP operation method/path/request/response/status and transport quotas | DOC-15 |
| Media byte/format/dimension/variant/public-original rules | DOC-17 |
| Queue/Redis/job identity and worker retry/DLQ rules | DOC-18 |
| Credential/MFA/session/CSRF/CORS/step-up/audit taxonomy/privacy/secrets/recovery | DOC-19 - this document |

### 1.3 Conflict rule

**CONFLICT RULE**

If a security mechanism would require a new API operation, permission key, Admin business page, PostgreSQL table/column, site context class or user-facing product capability, DOC-19 does not create it. The upstream authority must be revised first. Security may be stricter than transport/business convenience but may not silently broaden authority.

### 1.4 Controlled upstream reconciliation - GAP19-API-01 resolved

| Gap ID | RC1 finding | RC2 disposition |
|---|---|---|
| GAP19-API-01 | DOC-15 RC6 lacked canonical method/path/schema/status operations for login/logout, invitation acceptance/password setup, password reset, MFA, session termination and step-up. | RESOLVED in DOC-15 RC7. Exactly 11 API15-AUTH-* operations now own those HTTP transports; DOC-19 retains credential/session/MFA/CSRF/CORS/step-up security mechanics. |

**AUTHORITY-PRESERVING RECONCILIATION**

DOC-19 RC2 does not invent or modify an HTTP operation. It consumes the API15-AUTH-* registry created at the owning DOC-15 authority and verifies that the security mechanics below map to those transport homes without changing their method/path/schema/status contracts.

## 2. Frozen Security Invariants from DOC-01 through DOC-18

| Upstream | Inherited security rule |
|---|---|
| DOC-01 | One Central Admin/shared backend; 14 site identities; shared infrastructure never means shared ownership; no public user/account system is created. |
| DOC-02 | INVITED/ACTIVE/DISABLED only; normalized email login identifier; Super Admin MFA mandatory; no default/shared credentials; next protected request reflects disable/role/assignment changes; high-risk actions use step-up; tokens are secret/single-purpose/time-bounded. |

| Upstream | Inherited security rule |
|---|---|
| DOC-03 | No new security module/capability. Audit and approved Platform Settings exist; no raw secrets editor/server console. |
| DOC-04 | Missing site scope fails closed; authentication never authorizes a tenant; contexts are exact frozen classes; cross-site mismatch is a security defect. |
| DOC-05/11/13 | Preview is private/noindex; public PageData never carries Admin/session/Preview credentials; unknown-host 404 is neutral. |
| DOC-06/10 | 36 operational Admin pages only; authentication/access surfaces are non-module surfaces; every protected page authenticates ACTIVE session and reauthorizes server-side. |
| DOC-07 | Preview never publishes; permanent delete and other transitions retain their exact permission/state gates. |
| DOC-08 | admin_accounts contains identity/lifecycle only; no canonical sessions/secrets table; audit_events is append-only with event_code/details delegated here; runtime cannot update/delete audit rows. |
| DOC-09 | Preview path identity and host/site route resolution are fixed; security credentials cannot redefine canonical routing. |
| DOC-15 RC7 | ADMIN_SESSION / PREVIEW_AUTHORITY remain logical contexts; exactly 11 API15-AUTH-* operations provide authentication/security HTTP homes; Admin/Preview successes remain no-store; transport quota ceilings are fixed and DOC-19 may only tighten abuse controls. |
| DOC-16 | Search/SEO/sitemap never expose private/session state; security noindex/private rules preserved. |
| DOC-17 RC2 | Private canonical original never becomes anonymous public fallback; upload bytes must already satisfy media allowlist/limits. |
| DOC-18 RC2 | Workers use dedicated least-privilege credentials; queue payloads contain no auth/MFA/Preview/object-store secrets; Redis is not authorization; exact secret management is DOC-19. |

# 3. Security Architecture, Trust Zones and Stores

| Zone | Trust / data | Required boundary |
|---|---|---|
| Public site | Anonymous public reads; no Admin cookie authority | Trusted Host -> CTX-PUBLIC-SITE before site data; public response contains allowlisted data only. |
| Central Admin browser | Untrusted client holding opaque session cookie + CSRF token | Server authenticates session, ACTIVE account and current permission/site state on every protected request. |
| Preview browser | Private resource-bound temporary authority | Grant bound to canonical host + site + post + expiry; no propagation to ordinary public links. |
| Backend/API | Security policy enforcement point | Validates credentials, origin/CSRF, SiteContext, permission, object state and step-up before protected effect. |

| Zone | Trust / data | Required boundary |
|---|---|---|
| Security state store | Credential verifiers, MFA secrets, session/token records | Server-only, encrypted where secret, atomic TTL/revoke support; not public/API business data. |
| PostgreSQL | Canonical identity/roles/content/audit | DOC-08 schema/RLS unchanged; security store does not become business source of truth. |
| Workers/Redis/queue | Derived/internal processing | Dedicated service credentials; no user credentials/tokens in payloads; CTX-WORKER-SITE revalidation. |
| Secrets manager | Service/crypto keys | No Central Admin raw-secret editor; least-privilege workload access and rotation. |

```
Browser -> TLS -> Security gate -> Authentication -> Account ACTIVE
       -> CSRF/Origin (unsafe Admin requests)
       -> DOC-02 authorization -> DOC-04 context -> business/API handler
       -> DOC-08/RLS or DOC-18 worker effect

No later stage may "repair" a failed earlier security gate by broadening scope.
```

# 4. Admin Identity and Credential Binding

- `admin_id` from DOC-08 is the stable principal identity. Email/display name are not authority.
- Login lookup uses the frozen `email_normalized = lower(btrim(email))` comparison key. Input is trimmed for lookup only; the stored human email remains the canonical profile value.
- Credential state is bound one-to-one to `admin_id`; changing email does not create a new credential identity.
- INVITED cannot perform ordinary protected Admin operations. ACTIVE may authenticate/authorize. DISABLED is denied at the next protected request even when an old session exists.
- Public Author identity is never an Admin credential principal.
- No shared/team login, default production password, support bypass account, magic Super Admin header or wildcard credential exists.

# 5. Password Policy and Argon2id Verifier

| Control | Locked v1 rule |
|---|---|
| Length | 12-128 Unicode code points; maximum 512 UTF-8 bytes. Spaces/passphrases allowed. |
| Normalization | Do not trim, lowercase or Unicode-normalize password bytes. Verify exactly the UTF-8 sequence supplied after transport decoding. NUL is rejected. |
| Composition | No mandatory upper/lower/digit/symbol composition rule. Length and weak-password rejection are primary. |
| Weak-password check | Reject exact email/login identifier and a versioned local denylist of at least 10,000 common/known-weak passwords. No external network lookup is required at authentication time. |

| Control | Locked v1 rule |
|---|---|
| Hash algorithm | Argon2id; memory=65,536 KiB, iterations=3, parallelism=1, 16-byte random salt, 32-byte output. |
| Verification | Constant-time library verifier. Rehash on successful login when stored Argon2 parameters are below the current policy. |
| Storage | Only encoded Argon2id verifier record in the security credential store; never reversible password encryption or plaintext. |
| Rotation | No arbitrary periodic password expiry. Force reset on confirmed compromise/recovery or explicit authorized policy action. |
| Logging | Never log password length, bytes, hash, salt, candidate, password-derived fingerprint or reset secret. |

**CREDENTIAL-STORE BOUNDARY**

These verifier records are security-state objects, not new DOC-08 PostgreSQL tables. DOC-08 explicitly leaves password-hash persistence to PDF-19 while prohibiting a new canonical sessions/secrets table in its baseline.

# 6. Login and Authentication State Machine

1. Receive login identifier + password only through TLS. Apply abuse controls before expensive Argon2 work.
2. Normalize email for lookup using DOC-08 `lower(btrim(email))`. Return the same external failure message for unknown, INVITED, DISABLED and wrong-password cases.
3. If an ACTIVE credential exists, verify Argon2id. On failure record safe security telemetry and apply throttling; never reveal which check failed.
4. If account requires MFA (always Super Admin; otherwise when enrolled/policy requires), create a short-lived pre-auth challenge that is not an Admin session.
5. Verify TOTP/recovery factor. Rotate challenge identifiers after each successful factor transition to prevent fixation.
6. Create a new opaque server-side Admin session, rotate CSRF secret, and set the secure host-only session cookie.
7. On every protected request, re-read current account status and resolve current authorization/site assignment; session success is not permission caching.
8. Record AUTH.LOGIN.SUCCESS or privacy-safe AUTH.LOGIN.FAILURE. No credential material enters audit details.

| Authentication state | May call protected Admin API? | Expiry |
|---|---|---|
| ANONYMOUS | No | N/A |
| PREAUTH_PASSWORD_OK | No; MFA completion only | 5 minutes |
| AUTHENTICATED_SESSION | Yes, subject to fresh DOC-02 authorization | 30-minute idle / 12-hour absolute |
| STEP_UP_L1/L2 | Only same session; raises freshness for eligible high-risk actions | 10 minutes L1 / 5 minutes L2 |
| REVOKED/EXPIRED | No | Terminal |

# 7. Invitation, Password Setup and Activation

| Item | Locked rule |
|---|---|
| Invitation creation | Uses existing API15-G-031 and DOC-02 `admin_users.view + admin_users.invite`; account remains INVITED. |
| Token | 256-bit cryptographically random, single-purpose INVITE_SETUP, stored only as SHA-256 token hash; 48-hour expiry; one active setup token per invited account. |
| Delivery | Send only to the invited normalized email through approved delivery adapter. The raw token may exist only in the outbound message/link and transient request handling. |
| Acceptance | Validate hash, expiry, single-use state, current INVITED account and current invitation legitimacy; do not trust staged role/site grants as historical authority. |
| Setup | Set compliant password. Designated Super Admin must enroll/verify MFA before activation. Other Admins may enroll MFA during setup but activation does not require it unless current policy explicitly requires. |
| Activation | Transition INVITED -> ACTIVE only after setup conditions pass. Mark token consumed atomically. Existing planned assignments are evaluated from current DOC-02 state. |
| Reissue/revoke | A newly issued setup token invalidates older tokens. Invitation revoke makes the account DISABLED as frozen by DOC-02 and invalidates setup tokens. |
| Enumeration | Acceptance failure uses neutral invalid/expired response; never reveals other account/site/role data. |

**TRANSPORT RECONCILIATION**

Invitation creation remains API15-G-031. Invitation acceptance is API15-AUTH-003 and password setup/change is API15-AUTH-004 under DOC-15 RC7. DOC-19 defines token validation, activation and security mechanics only; the HTTP transport contract remains DOC-15 authority.

# 8. Password Change and Password Reset

## 8.1 Authenticated password change

- Requires current authenticated session plus current-password verification; if the session already carries valid L1 step-up, current-password re-entry may satisfy the same freshness requirement only once.
- New password passes Section 5. Password reuse history is not introduced because no upstream persistence supports it.
- On success write new Argon2id verifier, revoke all other Admin sessions and all outstanding reset tokens, rotate current session ID/CSRF secret, and audit AUTH.PASSWORD.CHANGED.

## 8.2 Reset request and completion

| Phase | Rule |
|---|---|
| Request | Always return a neutral acknowledgement. For ACTIVE accounts only, create a 256-bit RESET token hash with 30-minute expiry. INVITED uses invitation setup; DISABLED receives no usable reset authority although the response remains neutral. |
| Supersession | Creating a newer reset token invalidates all older unused reset tokens for the same admin_id. |
| Complete | Validate hash/expiry/current account, set a new compliant password, atomically consume token, revoke every Admin session and step-up proof for that admin_id. |
| MFA | Password reset does not disable MFA or bypass a mandatory MFA requirement. |
| Audit | Record request issuance only when an account matched internally; externally neutral. Record completion with no token/hash/password data. |

# 9. MFA Enrollment, Verification and Recovery

| Control | Locked TOTP rule |
|---|---|
| Method | TOTP compatible with RFC 6238 semantics; HMAC-SHA1, 6 digits, 30-second period for broad authenticator compatibility. |
| Secret | At least 160 random bits; Base32 provisioning representation; encrypted at rest with envelope encryption in security credential store. |
| Verification window | Accept current step plus one immediately previous/next time step. Track last accepted step and reject replay of the same/older accepted step for that credential. |
| Enrollment | Password-authenticated session + fresh password reauthentication; generate secret, require one successful TOTP verification before marking MFA enabled. |
| Super Admin | MFA is mandatory before owner-level protected operations and before initial Super Admin activation completes. |
| Recovery codes | Generate 10 one-time codes, each at least 128 random bits before display encoding. Show once; store only keyed hashes; consuming a code is atomic and audited. |
| Disable/replace | Requires current password + current TOTP/recovery proof. New secret invalidates old secret and unused recovery codes. |
| Lost factors | No hidden bypass. If no recovery code works, use the controlled security recovery runbook in Section 28; ordinary Admin-to-Admin MFA reset capability is not invented. |

# 10. Admin Session Contract, Cookies and Expiry

| Property | Locked rule |
|---|---|
| Session ID | 32 random bytes minimum (256 bits), opaque and meaningless. Store only a cryptographic hash of the bearer value in the server-side session store. |
| Cookie name | `__Host-bp_admin_session` |
| Cookie flags | Secure; HttpOnly; SameSite=Lax; Path=/; no Domain attribute; no client-readable expiry authority. |
| Idle expiry | 30 minutes since last accepted protected request. |
| Absolute expiry | 12 hours from authentication; cannot be extended by activity. No remember-me session in v1. |
| Touch behavior | Update last_seen at most once per 5 minutes to reduce store churn, but enforce idle expiry using current server time and recorded last activity. |
| Rotation | Rotate session ID after successful login/MFA completion, password change, and successful step-up creation. Old ID becomes immediately invalid. |
| Response cache | Protected Admin and Preview responses are `Cache-Control: no-store` as frozen by DOC-15. Browser back-forward cache must not reauthorize protected state after server denial. |
| Permissions | Session stores principal/authentication strength only; it does not embed a long-lived permission set or active site authority. |

## 10.1 Logical SessionRecord

```
SessionRecord {
  session_id_hash, admin_id, created_at, last_seen_at,
  idle_expires_at, absolute_expires_at, authn_strength,
  csrf_secret_hash, mfa_verified_at?, revoked_at?, revoke_reason?
}
// Logical security-state object only; not a DOC-08 table.
```

# 11. Session Revocation and Authorization Freshness

| Trigger | Required effect |
|---|---|
| Logout | Revoke current session before success is acknowledged; clear cookie. |
| Account DISABLED | Next protected request fails from authoritative DOC-08 status even if session row still exists; revoke all known sessions asynchronously/synchronously as defense in depth. |
| Site assignment removed / role changed | Next protected request re-resolves current DOC-02 authorization; session does not preserve stale grants. |
| Password reset complete | Revoke all sessions and all step-up proofs for account. |

| Trigger | Required effect |
|---|---|
| Password changed while authenticated | Revoke all other sessions; rotate current session only after new verifier commit. |
| MFA secret replaced/disabled | Revoke all outstanding step-up proofs and pre-auth challenges; current ordinary session may continue only if current policy allows. |
| Security incident / credential compromise | Operator runbook may revoke all sessions for account or globally without changing business permissions. |
| Permission-registry release | Protected request evaluates current registry semantics; no stale embedded permission manifest may remain authoritative. |

**NEXT-REQUEST INVARIANT**

The safest compliant implementation is to resolve account status, site assignment and effective permission set from authoritative state on every protected request. If an optimization cache is introduced later, invalidation must complete before the authority-changing mutation returns so the very next protected request observes the new state.

# 12. Step-Up / Reauthentication for High-Risk Actions

| Level | Required proof | Validity | Minimum use |
|---|---|---|---|
| L0 | Ordinary authenticated session | Session lifetime | Standard reads/creates/edits unless another frozen rule raises risk. |
| L1 | Current password reauthentication; include current MFA too when account has MFA enabled | 10 minutes; bound to one session/admin_id | Site-scoped permanent post/media/taxonomy/redirect deletion and other destructive site actions requiring step-up/reason under DOC-02/10. |
| L2 | Current password + valid MFA (enrollment required if absent) | 5 minutes; bound to one session/admin_id | Site disable/archive/deletion request/domain change; Admin disable/site-assignment change; GLOBAL role create/edit/retire/assign; Platform Settings edit. |
| L3 | Super Admin MFA + controlled recovery/transfer procedure; no reusable browser proof | Single operation / <=5 minutes | Super Admin recovery/transfer or equivalent owner-critical procedure. |

- Step-up never grants a permission; the API repeats the exact DOC-02 permission, scope, object and lifecycle checks after validating proof.
- Step-up proof is invalidated on logout, password/MFA change, session rotation not linked to the proof, account disable or explicit security revocation.
- A failed/expired step-up yields denial without performing the protected mutation. Confirmation UX from DOC-10 remains separate from cryptographic reauthentication.
- Reason text, where DOC-10/upstream requires a reason, is audit metadata and never substitutes for permission or step-up.

# 13. Preview Handoff and Private Preview Authority

| Stage | Locked behavior |
|---|---|
| Create handoff | Existing API15-S-016 is called only after `posts.view + posts.preview` and current target/site checks. It returns `preview_url` + `expires_at`; PageData contains no credential. |
| One-time grant | Generate 256-bit random PREVIEW_HANDOFF token, store only token hash bound to site_id + post_id + eligible source snapshot + initiating admin_id + expiry. Handoff token expires after 60 seconds and is single-use. |
| Cross-domain transfer | The raw one-time grant may be embedded only inside the returned `preview_url` as security credential material under DOC-19 mechanics. It must never be copied into ordinary PublicDestination links, analytics, referrers or PageData. |
| Exchange | At canonical owning host, validate token/site/post/eligibility, atomically consume it, create `__Host-bp_preview_session` host-only Secure HttpOnly SameSite=Lax cookie bound to site+post, then redirect to the clean frozen DOC-09 preview path without the grant. |
| Preview session | 10-minute absolute expiry; no renewal; no cross-post or cross-site authority; `Cache-Control: no-store`; `Referrer-Policy: no-referrer`; noindex from DOC-16. |
| Outgoing links | All links from Preview to normal Article/Category/Tag/Author/Search/Static pages are ordinary public links and do not propagate Preview cookie authority beyond the host-bound preview handler. |
| Revalidation | Each preview read revalidates owning site lifecycle, target eligibility and preview session binding before CTX-PREVIEW-SITE. |

**PREVIEW URL SAFETY**

The query credential is a one-time transport handoff only. The canonical Preview route identity remains DOC-09 authority, and the credential is removed from the browser URL immediately after successful exchange.

# 14. CSRF Protection

| Control | Rule |
|---|---|
| Scope | All credentialed Central Admin state-changing requests (POST/PUT/PATCH/DELETE and command-style unsafe requests). |
| Token | 256-bit random per-session CSRF secret. Browser sends `X-CSRF-Token`; server compares against the session-bound secret in constant time. |
| Origin | Also require exact allowed `Origin` for unsafe requests. Missing Origin may be accepted only for explicitly documented same-origin non-browser clients using a non-cookie authentication mechanism; v1 browser Admin is cookie-authenticated. |
| SameSite | Session cookie SameSite=Lax is defense in depth, not the sole CSRF control. |

| Control | Rule |
|---|---|
| Rotation | Rotate CSRF secret whenever Admin session ID rotates. Old CSRF token fails immediately. |
| Failure | Return existing authentication/validation denial semantics without protected payload; record SEC.CSRF.REJECT for repeated/suspicious cases. |
| Public/Preview | Anonymous public GETs do not use Admin CSRF. Preview one-time grant exchange is GET-like credential consumption but must be one-time, host-bound, no-store and immediately redirected clean. |

# 15. CORS and Origin Enforcement

| Surface | Locked rule |
|---|---|
| Central Admin API | Credentialed CORS allowed only from exact configured Central Admin origins. `Access-Control-Allow-Origin` reflects one exact allowlisted origin; never `*` with credentials. Allow only methods/headers required by the frozen DOC-15 operations plus `X-CSRF-Token`, `X-Request-ID` and `Idempotency-Key`. |
| Ordinary public API | Same-origin by default. Cross-origin anonymous read access is disabled unless an explicit deployment allowlist is approved; never include Admin cookies/credentials. |
| Preview | Only owning canonical public origin/host may exchange/use Preview authority. No third-party credentialed CORS. |
| Preflight | Validate origin before returning permissive headers. Cache preflight at most 600 seconds; origin policy changes must take effect without a browser session granting authority. |
| Null/file origins | Denied for credentialed/Admin/Preview requests. |
| Vary | Responses that emit origin-dependent CORS headers include `Vary: Origin`. |

# 16. Security Headers, TLS and Browser Isolation

| Header/control | Minimum contract |
|---|---|
| TLS | HTTPS only for Admin, Preview and public canonical traffic; insecure requests use existing canonical/deployment behavior, never send credentials over HTTP. |
| Strict-Transport-Security | `max-age=31536000`; `includeSubDomains` only where deployment authority confirms all subdomains are HTTPS-controlled; preload is deployment decision. |
| Content-Security-Policy | Default `default-src 'self'`; script execution from approved same-origin/assets with per-response nonce; no `unsafe-eval`; `object-src 'none'`; `base-uri 'self'`; `frame-ancestors 'none'` for Admin/Preview. Site-local public asset/CDN origins are explicit allowlists, never wildcard tenant shortcuts. |

| Header/control | Minimum contract |
|---|---|
| X-Content-Type-Options | `nosniff` |
| Referrer-Policy | Admin: `same-origin`; Preview: `no-referrer`; public: at least `strict-origin-when-cross-origin`. |
| Permissions-Policy | Disable camera, microphone, geolocation, payment, USB and other unused browser capabilities unless a later approved feature requires one. |
| Framing | Admin and Preview cannot be framed. Public pages may use `frame-ancestors` policy according to approved site needs but cannot weaken Admin/Preview. |
| Cache | Admin/Preview success and security-sensitive failure responses `no-store`; no shared cache may store session-specific HTML/JSON. |

# 17. Security Rate Limiting and Abuse Controls

DOC-15 RC7 transport quota ceilings remain authoritative for its 112 operations, including AUTH_LOGIN, AUTH_TOKEN, AUTH_RESET_REQUEST and AUTH_SESSION classes for API15-AUTH-*. The controls below are additional credential-abuse/security-risk throttles and may only make access stricter; they do not raise any DOC-15 ceiling.

| Logical action | Security throttle | Keying / behavior |
|---|---|---|
| Login failure | 5 failed attempts per normalized account per 15 min; 20 failed attempts per source IP per 15 min | On continued failure apply 1/2/4/8/16-second server delay, capped 16 s. After 10 account failures, 15-minute authentication cooldown; account status does not become DISABLED. |
| MFA challenge | 5 failed factors per 5 min per pre-auth/session + 20/IP/15 min | Invalidate challenge after limit; require fresh password authentication. |
| Password-reset request | 3/hour per normalized account and 10/hour per IP | Response remains neutral whether account exists. |
| Invite setup/reset token verification | 10 failures/hour per token family/IP | Do not reveal account/site data. |
| Preview handoff exchange | 10 failures/10 min per IP + existing PREVIEW_READ transport limit | Invalid/expired grants receive non-disclosing denial; repeated probes are security events. |
| Step-up verification | 5 failures/10 min per session/admin_id | Invalidate pending proof and require ordinary session reauthentication after limit. |
| Security-sensitive Global commands | Existing DOC-15 ADMIN_DESTRUCTIVE/ADMIN_SENSITIVE ceilings plus step-up | No security rule may relax transport limits. |

# 18. Input Validation, Output Encoding and Injection Safety

- Validate request shape against DOC-15/OpenAPI before business lookup. Unknown properties are rejected where the schema is closed.
- Use parameterized SQL/ORM bindings only. Site/permission/object identity is never concatenated into SQL, cache keys, storage paths or shell commands from raw client input.

- HTML rendering escapes untrusted text by default. DOC-07 ArticleBody types are allowlisted structured blocks; no raw script/style/HTML escape hatch is introduced.
- URLs are parsed structurally and then validated against the owning authority: DOC-09 routing/redirects, DOC-16 canonical/external rules, DOC-17 media URLs. Reject credential-bearing/unsafe schemes where upstream forbids them.
- CSV/audit export must neutralize spreadsheet formula injection for cells beginning with `=`, `+`, `-` or `@` by safe escaping/quoting in the export serializer.
- Error responses and validation details follow DOC-15 non-disclosure: do not confirm wrong-site/private target existence, credential existence or hidden authorization state.
- Never echo password/reset/MFA/Preview/session/secret values into validation errors, telemetry, audit details or client-visible exception traces.

# 19. Media / Upload Security Overlay

DOC-17 remains the owner of accepted MIME types, 20 MiB limit, 12,000-pixel/80 MP limits, one-frame decoding, private originals, sanitized native WebP and fixed derivative catalog. DOC-19 adds security process constraints without changing those media semantics.

| Security gate | Rule |
|---|---|
| Untrusted filename | Never use client filename as an object-store key or executable path. Store/display only sanitized metadata as DOC-17 permits. |
| Signature/decode | DOC-17 MIME/signature/decoder agreement is mandatory before acceptance. No SVG/archive/document executable formats are introduced. |
| Sandbox | Decode/transform in a constrained worker/process with memory/CPU/time limits; no network egress is required for decoding. |
| Malware/content scan | Run approved anti-malware/signature scan on uploaded bytes before media becomes ACTIVE/publicly usable. Scanner unavailable -> existing 503/unavailable behavior; malicious/invalid payload -> existing 422 validation behavior. |
| Metadata privacy | Canonical original remains private. Anonymous public derivative bytes follow DOC-17 metadata stripping; no GPS/EXIF/comments leak through public fallback. |
| Storage credentials | Object-store credentials are workload secrets, never upload payload fields, public URLs, audit details or worker messages. |
| Download headers | Private original delivery uses `Content-Disposition: attachment` unless an explicitly safe image preview is required; `nosniff` remains active. |

# 20. Secrets, Service Credentials and Key Rotation

| Secret class | Storage/use | Rotation / incident rule |
|---|---|---|
| DB runtime credentials | External secrets manager; separate site/platform/worker credentials matching DOC-08 grants | Rotate at least every 90 days and immediately on suspected exposure. |
| Object storage / CDN purge credentials | Secrets manager; workload-scoped to required bucket/namespace/purge function | At least every 90 days; revoke old key after successful cutover. |

| Secret class | Storage/use | Rotation / incident rule |
|---|---|---|
| Queue/Redis/search credentials | Secrets manager; dedicated service identity, not shared with public frontend | At least every 90 days; network ACL/TLS required where supported. |
| MFA envelope-encryption KEK | KMS/HSM-backed or equivalent secrets manager key; application receives only authorized encrypt/decrypt capability | Rotate at least annually and immediately on compromise; retain decrypt capability for old ciphertext only until rewrap completes. |
| CSRF/session randomness | Generated per session from CSPRNG; not a static secret | Never persisted as plaintext beyond required server-side session state. |
| Preview/reset/invite raw token | Generated one-time; only hash stored | Expires/consumes as Sections 7/8/13; raw value cannot be recovered. |
| Third-party delivery credential | Secrets manager; not platform_settings/site_settings | At least every 90 days or provider-required shorter period. |

- No production secret is committed to source control, Docker image layers, client bundles, `platform_settings`, `site_settings`, audit `details`, queue payloads or public PageData.
- Workloads receive only the secret references/credentials they need. Public frontend applications receive no Admin/DB/Redis/object-store private credential.
- Rotation must support overlap or atomic switchover; never make a secret rotation dependent on weakening authentication or tenant isolation.
- Break-glass secret access is an operational incident path, not a new Admin feature; it must be logged externally and followed by immediate rotation.

# 21. Security-State Persistence Boundary

**NO DOC-08 SCHEMA CHANGE**

DOC-08 explicitly left password hashes, MFA, reset/invite/session tokens and secret storage to PDF-19 while its canonical schema contains no sessions/secrets table. DOC-19 therefore defines logical security-state records and durability/atomicity requirements, not new PostgreSQL tables or columns.

| Logical record | Durability / confidentiality | Minimum fields |
|---|---|---|
| CredentialRecord | Durable; verifier confidential but not reversible secret | admin_id, password_verifier, algorithm/params, changed_at |
| MfaRecord | Durable; TOTP secret envelope-encrypted; recovery codes hashed | admin_id, encrypted_secret, enabled_at, recovery_hashes, last_accepted_step |
| SessionRecord | Shared server-side TTL state; bearer ID stored hashed | session_id_hash, admin_id, created/last_seen/idle/absolute expiry, csrf hash, strength, revoke state |
| OneTimeTokenRecord | Shared/durable through expiry; token stored hashed only | token_hash, purpose, admin_id or preview site/post binding, issued_at, expires_at, consumed_at |
| StepUpRecord | Short-lived server-side state | session hash, admin_id, level, issued_at, expires_at, revoked_at |
| SecurityThrottleState | Short-lived atomic counters/windows | normalized subject hash, source network key, action family, count, window/reset |

Physical provider/package/key mapping belongs to DOC-23/24. The selected security store must be shared across horizontally scaled API instances, use server-side TLS/authentication, support atomic compare-and-consume/revoke, survive normal process restart for durable credential/token records, and enforce TTL for ephemeral sessions/challenges. If Redis is selected for any of these records, DOC-18 must be amended to reserve security namespaces rather than silently mixing them into the cache/job key registry.

# 22. Audit Architecture and Event Dictionary

DOC-08 `audit_events` remains the physical append-only authority. DOC-19 owns stable `event_code` vocabulary, privacy-safe details and which security/high-risk outcomes require an event. Every successful state-changing Admin action required by DOC-10 has an auditable code; high-risk denials/security incidents also generate events.

| Event family | Canonical codes (representative complete family) | When recorded |
|---|---|---|
| Authentication | AUTH.LOGIN.SUCCESS; AUTH.LOGIN.FAILURE; AUTH.LOGOUT; AUTH.SESSION.EXPIRED; AUTH.SESSION.REVOKED; AUTH.STEPUP.SUCCESS; AUTH.STEPUP.FAILURE | Authentication/session/security-strength lifecycle. |
| Password/MFA | AUTH.PASSWORD.SET; AUTH.PASSWORD.CHANGED; AUTH.RESET.REQUESTED; AUTH.RESET.COMPLETED; AUTH.MFA.ENROLLED; AUTH.MFA.DISABLED; AUTH.MFA.RECOVERY_USED; AUTH.MFA.FAILURE | Credential-factor changes and security-relevant failures. |
| Invitation/account | AUTH.INVITE.CREATED; AUTH.INVITE.REISSUED; AUTH.INVITE.ACCEPTED; AUTH.INVITE.REVOKED; ACCOUNT.PROFILE.UPDATED; ACCOUNT.ENABLED; ACCOUNT.DISABLED | DOC-02 account lifecycle. |
| Assignments/roles | AUTHZ.SITE_ASSIGNED; AUTHZ.SITE_UNASSIGNED; AUTHZ.SITE_ROLE_ASSIGNED; AUTHZ.SITE_ROLE_UNASSIGNED; AUTHZ.GLOBAL_ROLE_ASSIGNED; AUTHZ.GLOBAL_ROLE_UNASSIGNED; ROLE.CREATED; ROLE.UPDATED; ROLE.RETIRED; ROLE.DUPLICATED | Authority changes; before/after permission/assignment diff when applicable. |
| Post/editorial | POST.CREATED; POST.UPDATED; POST.PUBLISHED; POST.SCHEDULED; POST.RESCHEDULED; POST.UNSCHEDULED; POST.ARCHIVED; POST.TRASHED; POST.RESTORED; POST.PERMANENTLY_DELETED; POST.DUPLICATED; POST.REVISION_RESTORED | State-changing editorial actions. |
| Taxonomy/author | CATEGORY.CREATED; CATEGORY.UPDATED; CATEGORY.DELETED; TAG.CREATED; TAG.UPDATED; TAG.MERGED; TAG.DELETED; AUTHOR.CREATED; AUTHOR.UPDATED; AUTHOR.RETIRED | Approved taxonomy/author mutations only. |
| Media | MEDIA.UPLOADED; MEDIA.METADATA_UPDATED; MEDIA.REPLACED; MEDIA.DELETED | User-visible media mutations; derivative worker telemetry is not duplicated into one audit row per variant. |
| Navigation/SEO/redirect/search | NAVIGATION.UPDATED; HOMEPAGE.CONTROL_UPDATED; SEO.UPDATED; REDIRECT.CREATED; REDIRECT.UPDATED; REDIRECT.DELETED; SEARCH.REINDEX_REQUESTED | Approved same-site configuration/commands. |

| Event family | Canonical codes (representative complete family) | When recorded |
|---|---|---|
| Site/global | SITE.CREATED; SITE.ENABLED; SITE.DISABLED; SITE.ARCHIVED; SITE.DELETION_REQUESTED; SITE.DOMAIN_CHANGED; PLATFORM.SETTING_UPDATED; AUDIT.EXPORTED | High-impact/global actions. |
| Security | SEC.CSRF.REJECT; SEC.CORS.REJECT; SEC.RATE_LIMIT; SEC.CROSS_SITE.DENIED; SEC.PRIVILEGE_ESCALATION.DENIED; SEC.PREVIEW.DENIED; SEC.UPLOAD.REJECTED; SEC.SECRET.ROTATED; SEC.RECOVERY.INITIATED; SEC.RECOVERY.COMPLETED | Repeated/meaningful security denials and incident/recovery activity. |

**EVENT-CODE STABILITY**

Display labels may evolve, but canonical `event_code` values are stable traceability keys. A new event code may describe an existing frozen action/security outcome; it must not imply a new capability.

# 23. Audit Detail, Immutability and Privacy Minimization

| Audit field | DOC-19 rule |
|---|---|
| scope/site_id | SITE event requires site_id; GLOBAL follows DOC-08. Never infer GLOBAL from missing site. |
| actor_type/actor_admin_id | ADMIN for authenticated action; SYSTEM for scheduled/worker/security system effect. Actor ID remains historical even after account disable. |
| module_key/action_key | Use existing module/capability/action identifier where applicable; security-only events may use SECURITY/AUTH logical group without creating a module. |
| target_type/target_id | Include only stable target identity already authorized/known; security denial may omit target_id to avoid confirming existence. |
| request_id | Propagate DOC-15 request/correlation ID where available; child worker/system events may link via safe correlation string. |
| outcome | Exactly SUCCESS / DENIED / FAILED as DOC-08. |
| details | Allowlisted compact object only: changed_field_names, before/after authority diff, reason code/text where required, step-up level, safe client/security fingerprint. Never full article body, password/token/hash/MFA secret, raw media, object key or private URL. |

## 23.1 Client/network metadata

- `audit_events.details` may store a one-way HMAC source-network fingerprint and coarse IP network prefix (IPv4 /24, IPv6 /56) for high-risk/security events; do not store full raw user-agent strings.
- Raw source IP and full request security telemetry, if needed for incident investigation, lives in restricted operational security logs for the shorter retention in Section 24, not in ordinary Audit Detail.
- Audit viewers require existing `audit.view`; export requires `audit.view + audit.export`. Export applies the same privacy redaction as on-screen detail and spreadsheet-injection safety.

- Runtime roles never UPDATE/DELETE audit_events. Retention purge is a separately privileged maintenance/operations procedure after the policy horizon and legal-hold checks.

# 24. Privacy, Consent and Retention Policy

| Data class | Retention / rule |
|---|---|
| audit_events | 365 days online minimum from occurred_at, then eligible for privileged purge/archive subject to legal hold and PDF-20/24 backup retention. Append-only during active retention. |
| Authentication/security telemetry with raw IP | 30 days maximum by default; restricted to security/operations access; longer retention requires documented incident/legal hold. |
| Session/pre-auth/step-up records | Expire by their security TTL; physically purge within 24 hours after terminal expiry/revocation except minimal audit event. |
| Reset/Preview one-time token records | Purge within 24 hours after consume/expiry. Raw token is never retained. |
| Invitation token records | Purge token state within 7 days after consume/expiry/revocation; Admin identity remains according to DOC-02 lifecycle. |
| MFA recovery-code hashes | Until used, regenerated or MFA disabled; used hashes may retain consumed marker only until next code regeneration, then purge. |
| Credential verifiers | Until replaced/account security recovery; previous verifier is not retained as password history in v1. |
| Secrets access logs | 90 days minimum; no secret values. |

## 24.1 Consent boundary

- v1 has no public account system and the Contact static page has no submission form, so DOC-19 does not invent public consent/account/profile features.
- Central Admin authentication/CSRF/Preview cookies are strictly necessary security cookies and are not used for advertising/profile tracking.
- Core public runtime must not set non-essential analytics/marketing cookies merely because `analytics_verification` identifiers exist. If a future site wants non-essential tracking that legally requires consent, the corresponding consent mechanism must be approved upstream before those cookies/scripts are enabled.
- Privacy Policy remains one of the five frozen read-only static pages. DOC-19 defines handling requirements but does not create a generic privacy-page editor.

# 25. Destructive-Action Security Matrix

| Action class | Existing authority | Extra DOC-19 control |
|---|---|---|
| Permanent Post delete | posts.view + posts.edit + posts.delete + DOC-07 state/version gates | DOC-10 confirmation + L1 step-up + reason where UI contract requires; audit POST.PERMANENTLY_DELETED. |
| Permanent media/taxonomy/redirect deletion | Exact DOC-02 permission composite + same-site checks | L1 step-up; re-check current usages/relationships/redirect safety; atomic deny on missing proof. |
| Site disable/archive/deletion request/domain change | Exact GLOBAL site/domain permissions | L2 step-up; MFA mandatory for the action; audit before/after lifecycle/domain context. |

| Action class | Existing authority | Extra DOC-19 control |
|---|---|---|
| Admin disable / site assignment change | Exact GLOBAL admin_users permission | L2 step-up; cannot leave stale session authority; audit authority diff. |
| GLOBAL role create/edit/retire/assign | Exact roles permissions + privilege ceiling | L2 step-up; re-evaluate actor privilege ceiling immediately before commit; audit permission/assignment diff. |
| Platform Settings edit | platform_settings.view + platform_settings.edit | L2 step-up; no raw secret setting; audit key and redacted before/after. |
| Super Admin recovery/transfer | Owner-level controlled procedure under DOC-02 | L3; mandatory MFA/strong verification; no ordinary browser bypass; external operations approval/evidence + audit. |

# 26. Admin, Public and Worker Security Boundaries

| Surface | Must do | Must never do |
|---|---|---|
| Central Admin | Secure session + CSRF/origin + fresh DOC-02 authorization + CTX-ADMIN-SITE/CTX-GLOBAL | Treat active-site selector/session/MFA as tenant or permission authority. |
| Public frontend | Resolve trusted Host/site; render only DOC-13 public data; no Admin secret | Receive all-site data, DB credentials, Redis/queue access, audit/session material. |
| Preview | Use short-lived resource/site-bound Preview authority; no-store/no-referrer | Publish, index, propagate grant into ordinary links or use a grant for another site/post. |
| Workers | Dedicated least-privilege service credential; CTX-WORKER-SITE + RLS + current-state revalidation | Carry user passwords/MFA/session/Preview tokens or infer site from missing scope. |
| Global system coordinator | Use frozen CTX-GLOBAL only for approved global registry/management work | Use missing site context as all-site content authority. |

# 27. Incident Classification and Containment

| Incident | Immediate containment | Required follow-through |
|---|---|---|
| Admin credential compromise | Revoke account sessions/step-up/reset tokens; force password reset; preserve account status unless authorized disable is needed | Review audit/security telemetry; rotate MFA if factor exposure suspected; record SEC.RECOVERY.*. |
| Super Admin compromise | Revoke all owner sessions; invoke L3 recovery; consider authorized account disable only if continuity permits | Independent identity verification; rotate owner credential/MFA; audit externally and in audit_events. |
| Session/Preview token leak | Revoke affected token/session family; rotate session or Preview grant keys if systemic | Check referrer/access logs; enforce no-store/no-referrer; validate no cross-site exposure. |
| Service secret exposure | Revoke/rotate credential immediately; restrict network/workload identity | Audit blast radius; rotate dependent credentials; invalidate sessions only if an authentication key was affected. |
| Cross-site data leak suspicion | Stop affected handler/worker; fail closed; if necessary use existing authorized site disable only through its frozen control | Preserve evidence, identify request/site IDs, verify RLS/context boundaries, repair code before re-enable. |

| Incident | Immediate containment | Required follow-through |
|---|---|---|
| Malicious upload | Quarantine/reject bytes; ensure media never becomes ACTIVE/public | Record upload rejection/security telemetry; do not retain unsafe public derivative. |
| Audit integrity concern | Stop writer path if immutability bypass suspected; preserve DB/log evidence | Verify runtime grants and append-only policy; compare request/security telemetry; restore through controlled DB recovery only. |

# 28. Credential, Account and Security Recovery Runbooks

## 28.1 Lost-password / normal Admin recovery

1. Use password-reset flow; neutral request; 30-minute single-use token.
2. On completion revoke every session/step-up proof; retain MFA enrollment.
3. User logs in with new password and existing MFA if applicable.
4. Audit reset completion; never store reset token in audit.

## 28.2 Lost MFA with usable recovery code

1. Authenticate password and consume one recovery code atomically.
2. Permit MFA replacement enrollment in the same controlled recovery session.
3. Invalidate old TOTP secret and all old recovery codes.
4. Rotate Admin session; revoke step-up proofs; audit recovery use and new enrollment.

## 28.3 Lost Super Admin factors / owner recovery

1. Do not use ordinary role/Admin UI to bypass MFA. Enter L3 incident procedure.
2. Verify designated owner identity using organization-controlled out-of-band evidence defined in operations runbook; require two-person operational approval where staffing permits.
3. Temporarily revoke all owner sessions and old MFA factor; create one controlled recovery ceremony with <=30-minute operational window, not a reusable bypass credential.
4. Set new password + mandatory MFA; rotate recovery codes; close recovery authority immediately.
5. Audit owner recovery and retain external incident evidence according to Section 24/security-log retention.

## 28.4 Platform secret recovery

1. Revoke leaked key at provider/secret manager.
2. Provision replacement under least-privilege workload identity.
3. Deploy dual-key/overlap where required for encrypted data rewrap; never turn off authentication/RLS during cutover.
4. Verify dependent API/worker/media flows under each tenant class.
5. Remove old decrypt/credential access after successful rewrap/cutover and audit rotation.

# 29. Security Logging, Metrics and Alert Signals

| Signal | Dimensions / minimum semantics |
|---|---|
| auth_login_total | outcome; never raw email |
| auth_mfa_total | outcome, method=TOTP\|RECOVERY |

| Signal | Dimensions / minimum semantics |
|---|---|
| session_revocation_total | reason |
| stepup_total | level, outcome |
| csrf_reject_total | surface |
| cors_reject_total | surface |
| security_rate_limit_total | action_family |
| cross_site_denial_total | surface/context class; no target metadata leak |
| preview_grant_total | create/exchange/expire/reject |
| upload_security_reject_total | reason_class only |
| secret_rotation_total | secret_class, outcome |
| audit_write_failure_total | event_family; any nonzero sustained value is critical |
| security_recovery_total | type, outcome |

- Logs carry request_id/correlation ID and safe admin_id/site_id only on internal protected telemetry where access is restricted. Public errors do not expose them as tenant hints.
- No passwords, token values/hashes, TOTP secrets, recovery codes, session bearer IDs, private media URLs, raw object keys, Redis/queue credentials or ArticleBody content in security logs.
- Exact alert thresholds, SIEM/vendor, on-call routing and platform-wide SLOs are PDF-20/23/24 authority; DOC-19 freezes signal meaning and mandatory critical conditions such as audit-write failure, cross-site access, repeated owner login failure and secret-compromise recovery.

# 30. Threat and Failure Semantics

| Threat/failure | Required outcome |
|---|---|
| Unknown email / wrong password / disabled account | Externally indistinguishable login failure; no account enumeration. |
| Expired/used invite-reset-Preview token | Neutral invalid/expired denial; never revive token. |
| Stolen Admin session without CSRF token | Unsafe browser request rejected by CSRF + Origin checks; GET/read still limited by session permissions and no-store. |
| Stale permission embedded in browser | Server ignores as authority and re-resolves DOC-02 state. |
| Cross-site UUID probing | 404-equivalent non-disclosure under current SITE context; security event on repeated/malicious pattern. |
| MFA replay | Reject already accepted TOTP step; recovery code single-use. |
| Session store unavailable | Protected Admin/Preview fails closed (503/unavailable where transport permits); never fall back to anonymous privilege or stale local cache. |
| Credential store unavailable | Login/setup/reset fails unavailable; existing sessions may continue only if session validation and current account authorization remain authoritative. |

| Threat/failure | Required outcome |
|---|---|
| Audit write fails during high-risk mutation | High-risk/destructive/authority-changing mutation fails closed unless upstream explicitly permits an audit-after-commit pattern; v1 requires audit event transaction/commit coupling at service level as far as stores permit. |
| Secrets manager unavailable | Do not use hardcoded fallback secret. Existing in-memory credential may remain only until its normal process/session validity; new secret-dependent operation fails closed. |
| Clock skew | Security services use synchronized UTC; token/TOTP expiry evaluated server-side. TOTP accepts only Section 9 +/-1 step window. |

# 31. End-to-End Execution Examples

## 31.1 Login -> MFA -> SITE mutation

```
1) Email/password -> neutral account lookup + Argon2id
2) If MFA required -> 5-minute PREAUTH challenge -> TOTP verify
3) Create __Host-bp_admin_session + CSRF secret
4) PATCH/POST Admin call -> Origin + X-CSRF-Token
5) Session -> ACTIVE admin_id -> current site assignment/permissions
6) DOC-04 CTX-ADMIN-SITE -> target ownership/state -> mutation
7) audit_event with safe event_code/details -> no secret values
```

## 31.2 Destructive site operation

```
1) Existing GLOBAL operation and permission path from DOC-15/DOC-02
2) Require L2 step-up: current password + MFA, <=5 min
3) Re-check account ACTIVE + exact GLOBAL permission + privilege constraints
4) DOC-10 confirmation/reason -> atomic operation
5) Append SITE.* audit event with before/after lifecycle/domain context
6) Revoke/refresh affected sessions/caches only as upstream effects require
```

## 31.3 Preview handoff

```
Admin API15-S-016 -> one-time 60s grant in preview_url
Owning site consumes grant -> host-only 10m preview session -> clean redirect
Preview GET -> CTX-PREVIEW-SITE + target eligibility -> no-store/no-referrer/noindex
Ordinary outgoing links -> no Preview credential propagation
```

# 32. Cross-Document Consistency Audit

| Authority | Result | Verification |
|---|---|---|
| DOC-01 | PASS | No public-account/security product added; one Admin/shared backend and 14-site ownership preserved. |
| DOC-02 | PASS | Three states, 69 permissions, Super Admin MFA, next-request revocation, step-up classification preserved. |

| Authority | Result | Verification |
|---|---|---|
| DOC-03 | PASS | No new capability/module/permission; audit/security mechanics implement existing features only. |
| DOC-04 | PASS | Frozen context names retained; authentication never replaces SiteContext; fail-closed tenant rules preserved. |
| DOC-05/06 | PASS | No new public/Admin operational Page ID; auth/access surfaces remain non-module. |
| DOC-07 | PASS | No content state/transition changed; destructive and Preview semantics preserved. |
| DOC-08 | PASS | No PostgreSQL table/column added; credential/session records are external logical security state; audit_events physical shape/append-only retained. |
| DOC-09 | PASS | Preview canonical path identity preserved; one-time security handoff does not redefine routing. |
| DOC-10/11 | PASS | Session denial, confirmations, reauth handoff and public/Preview error semantics preserved. |
| DOC-12/13/14 | PASS | No visual/data schema/frontend cross-site authority changed; credentials remain absent from PageData. |
| DOC-15 RC7 | PASS after RC7 | GAP19-API-01 is closed at the HTTP authority: exactly 11 API15-AUTH-* operations provide login/logout, invitation/setup, reset, MFA, session termination and L1/L2 step-up transport; DOC-19 retains security mechanics. |
| DOC-16 RC4 | PASS | Noindex/search/sitemap/canonical behavior unchanged; private security state excluded. |
| DOC-17 RC2 | PASS | Upload security overlays existing validation; private original and sanitized public baseline preserved. |
| DOC-18 RC2 | PASS | Worker secrets/least-privilege and no-secret-payload rules preserved; no queue/cache key redefinition. |

## 32.1 DOC-15 RC7 canonical authentication HTTP homes

| Operation ID | Method / path | Success | Logical auth context |
|---|---|---|---|
| API15-AUTH-001 | POST /api/v1/auth/login | 200 | NONE |
| API15-AUTH-002 | POST /api/v1/auth/logout | 204 | ADMIN_SESSION |
| API15-AUTH-003 | POST /api/v1/auth/invitations/accept | 200 | INVITE_SETUP_TOKEN |
| API15-AUTH-004 | POST /api/v1/auth/password/setup | 200 | INVITE_SETUP_TOKEN_OR_ADMIN_SESSION |
| API15-AUTH-005 | POST /api/v1/auth/password-reset/request | 202 | NONE |
| API15-AUTH-006 | POST /api/v1/auth/password-reset/complete | 204 | RESET_TOKEN |

| Operation ID | Method / path | Success | Logical auth context |
|---|---|---|---|
| API15-AUTH-007 | POST /api/v1/auth/mfa/enrollment | 200 | ADMIN_SESSION_OR_INVITE_SETUP_TOKEN |
| API15-AUTH-008 | POST /api/v1/auth/mfa/verify | 200 | MFA_CHALLENGE |
| API15-AUTH-009 | POST /api/v1/auth/mfa/recovery | 200 | MFA_CHALLENGE |
| API15-AUTH-010 | POST /api/v1/auth/sessions/terminate | 204 | ADMIN_SESSION |
| API15-AUTH-011 | POST /api/v1/auth/step-up | 200 | ADMIN_SESSION |

**RC7 RECONCILIATION CHECK**

All 11 operation IDs, methods, paths and success statuses above are inherited from DOC-15 RC7/OpenAPI. API15-AUTH-004 covers invited password setup and authenticated password change. API15-AUTH-011 creates reusable L1/L2 step-up state only; L3 remains the controlled recovery/transfer procedure defined by DOC-19.

**CONSISTENCY VERDICT**

DOC-15 RC7 closes the former authentication/access-surface transport dependency at the owning HTTP authority. No blocking contradiction or missing upstream dependency is identified for DOC-19 security mechanics after RC7 reconciliation.

# 33. Traceability Registry

| Trace ID | Relationship |
|---|---|
| TR19-001 | DOC-02 account states -> Sections 4, 6-11 |
| TR19-002 | DOC-02 Super Admin MFA -> Section 9/L3 recovery |
| TR19-003 | DOC-02 high-risk classification -> Sections 12 and 25 |
| TR19-004 | DOC-04 SiteContext/fail-closed -> Sections 3, 11, 13, 26, 30 |
| TR19-005 | DOC-08 admin_accounts identity-only -> Sections 4 and 21 |
| TR19-006 | DOC-08 audit_events -> Sections 22-24 |
| TR19-007 | DOC-10 common session gate -> Sections 6, 10, 11 |
| TR19-008 | DOC-10 confirmations/destructive effects -> Sections 12, 25 |
| TR19-009 | DOC-13 Preview credential exclusion -> Section 13 |
| TR19-010 | DOC-15 ADMIN_SESSION/PREVIEW_AUTHORITY -> Sections 6, 10, 13 |
| TR19-011 | DOC-15 quotas -> Section 17 stricter-only throttles |
| TR19-012 | DOC-17 upload/private original -> Section 19 |
| TR19-013 | DOC-18 worker secrets/no-token payloads -> Sections 20 and 26 |
| TR19-014 | DOC-15 RC7 API15-AUTH-001..011 reconciliation -> Sections 1.4, 32.1 and freeze checklist |
| TR19-015 | PDF-20 observability/DR handoff -> Sections 24, 29, 35 |

| Trace ID | Relationship |
|---|---|
| TR19-016 | PDF-21 security tests -> Section 34 acceptance IDs |
| TR19-017 | PDF-23/24 provider/deployment selection -> Sections 20, 21, 35 |

# 34. Comprehensive Acceptance Criteria

| Acceptance ID | Family | Release assertion |
|---|---|---|
| QA19-001 | Identity | Protected request requires valid session + ACTIVE account before authorization. |
| QA19-002 | Identity | INVITED/DISABLED cannot obtain ordinary protected access. |
| QA19-003 | Identity | Email lookup uses frozen lower(btrim(email)) normalization without making display email authority. |
| QA19-004 | Password | Password verifier is Argon2id with exact Section 5 parameters. |
| QA19-005 | Password | Password input is not silently trimmed/normalized. |
| QA19-006 | Password | No plaintext/reversible password or password material enters logs/audit. |
| QA19-007 | Login | Unknown/wrong/disabled externally share neutral failure behavior. |
| QA19-008 | Login | Super Admin cannot complete owner-level access without MFA. |
| QA19-009 | MFA | TOTP replay outside/within accepted-step rules is rejected. |
| QA19-010 | MFA | Recovery codes are one-time and only hashes are stored. |
| QA19-011 | Session | Admin session bearer has >=256 bits entropy and server stores only its hash. |
| QA19-012 | Session | Cookie flags/name exactly match Section 10. |
| QA19-013 | Session | 30-minute idle and 12-hour absolute expiry are server enforced. |
| QA19-014 | Session | Logout revokes current session before success. |
| QA19-015 | Session | Password reset revokes all sessions/step-up proofs. |
| QA19-016 | Authorization | Session never freezes roles/permissions/site assignment across next request. |
| QA19-017 | Authorization | SiteContext still derives from DOC-04 after authentication. |
| QA19-018 | CSRF | Every unsafe cookie-authenticated Admin request requires valid session CSRF token and allowed Origin. |

| Acceptance ID | Family | Release assertion |
|---|---|---|
| QA19-019 | CORS | Credentialed Admin CORS never uses wildcard origin. |
| QA19-020 | Headers | Admin/Preview apply required no-store/framing/CSP/nosniff/referrer controls. |
| QA19-021 | Rate limit | Security throttles can only tighten, never raise DOC-15 transport ceilings. |
| QA19-022 | Invite | Invite setup token is 256-bit, hashed, single-use and <=48h. |
| QA19-023 | Reset | Password-reset response does not enumerate account existence. |
| QA19-024 | Reset | Reset token is single-use, hashed and <=30m. |
| QA19-025 | Step-up | L1/L2 proof never substitutes for permission/target/state validation. |
| QA19-026 | Step-up | L2 requires MFA and expires <=5m. |
| QA19-027 | Preview | Preview handoff grant is one-time <=60s and bound to site/post. |
| QA19-028 | Preview | Preview session is host/site/post-bound <=10m and no-store/no-referrer. |
| QA19-029 | Preview | Preview credential never enters PageData/ordinary PublicDestination. |
| QA19-030 | Input | Unknown/invalid request fields follow OpenAPI validation; SQL uses parameterization. |
| QA19-031 | Output | User/editor text is escaped/allowlisted; raw script/style injection is not introduced. |
| QA19-032 | Upload | Upload security cannot weaken DOC-17 MIME/signature/size/dimension validation. |
| QA19-033 | Upload | Malware scan failure/invalid payload maps to existing transport error classes without inventing status. |
| QA19-034 | Secrets | No service secret exists in platform_settings/site_settings/client bundle/source code. |
| QA19-035 | Secrets | Runtime workloads receive least-privilege secret access and emergency rotation is supported. |
| QA19-036 | Security store | No new DOC-08 session/secrets PostgreSQL table/column is required. |
| QA19-037 | Security store | Session/token store supports atomic consume/revoke and shared multi-instance access. |
| QA19-038 | Audit | Every required successful state-changing Admin action records one stable event_code family. |
| QA19-039 | Audit | Authority/site/global destructive changes include required before/after/reason context where applicable. |
| QA19-040 | Audit | Runtime cannot UPDATE/DELETE audit_events. |

| Acceptance ID | Family | Release assertion |
|---|---|---|
| QA19-041 | Audit | Audit details contain no password/token/MFA/private media/secret values. |
| QA19-042 | Audit | Wrong-site denial does not confirm target metadata. |
| QA19-043 | Privacy | Raw IP telemetry default retention <=30 days unless incident/legal hold. |
| QA19-044 | Privacy | Audit-event online retention follows 365-day policy and privileged purge rules. |
| QA19-045 | Privacy | Core public runtime sets no non-essential analytics/marketing cookies without approved consent mechanism. |
| QA19-046 | Worker | Worker/queue payloads remain free of user/session/Preview/service secret values. |
| QA19-047 | Recovery | Lost Super Admin factors do not use hidden bypass; L3 controlled recovery is required. |
| QA19-048 | Recovery | Secret compromise can revoke/rotate without disabling RLS/authorization. |
| QA19-049 | Incident | Cross-site mismatch is treated as security incident and fails closed. |
| QA19-050 | Availability | Security-state store outage never grants fallback access. |
| QA19-051 | Availability | Secrets manager outage never falls back to hardcoded/default secret. |
| QA19-052 | Telemetry | Required security metrics exist and contain no raw credentials. |
| QA19-053 | API boundary | DOC-19 consumes API15-AUTH-001..011 and does not redefine their methods, paths, request/response schemas or success statuses. |
| QA19-054 | API boundary | DOC-15 RC7 contains all 11 canonical API15-AUTH-* operations and their logical auth contexts align with DOC-19 credential/session/MFA/step-up mechanics. |
| QA19-055 | Traceability | All QA19 criteria map to DOC-02/04/08/10/15/17/18 as applicable. |
| QA19-056 | Tenant | Admin/Preview cookies cannot authorize another public site/tenant. |
| QA19-057 | Tenant | No session is used as missing-site -> all-sites fallback. |
| QA19-058 | Destructive | High-risk mutation fails atomically when required step-up/audit security gate fails. |
| QA19-059 | Audit export | Audit export preserves `audit.view + audit.export`, privacy redaction and CSV formula safety. |
| QA19-060 | Credential lifecycle | Password/MFA changes invalidate obsolete preauth/reset/step-up material. |

| Acceptance ID | Family | Release assertion |
|---|---|---|
| QA19-061 | Token lifecycle | Consumed/expired one-time tokens can never be replayed. |
| QA19-062 | Clock | Expiry/TOTP evaluation uses synchronized server UTC. |
| QA19-063 | Public | Ordinary public pages receive no Admin/Preview/session/security-state fields. |
| QA19-064 | Frontend | Site-local public apps receive no Redis/DB/queue/secret credentials. |
| QA19-065 | Freeze | Cross-document audit contains no unresolved blocking contradiction or missing dependency within DOC-19 scope. |
| QA19-066 | Freeze | All header/session/token/step-up values in Appendix A/D match normative sections. |
| QA19-067 | Freeze | PDF-21 may expand tests but cannot weaken QA19 expected outcomes. |

Acceptance baseline: 67 release-blocking QA19 assertions. GAP19-API-01 is resolved by DOC-15 RC7; formal DOC-19 freeze requires every applicable assertion to pass and explicit approval of this review candidate.

# 35. Dependencies, Downstream Handoff and Freeze Readiness

| Later authority | May define | May not redefine |
|---|---|---|
| PDF-20 Performance/DR/Observability | Capacity, alert thresholds, security-log storage sizing, backup/RPO/RTO and incident availability targets | Credential semantics, session expiry, tenant/security correctness, audit/privacy retention floor without controlled DOC-19 change. |
| PDF-21 QA | Executable security/integration/abuse/cross-site test harness | QA19 expected outcomes. |
| PDF-22 Traceability | Master requirement -> implementation -> test matrix | Authority ownership/IDs. |
| PDF-23 Engineering Architecture | Concrete auth library, security-state provider, secrets manager/KMS, mail adapter, WAF/reverse-proxy packages | Logical security state, Argon2/TOTP/session/CSRF/CORS/step-up semantics. |
| PDF-24 Deployment | TLS certificates, environment secret injection, network policy, key rotation deployment/runbooks | No hardcoded secret or weakened runtime grants. |
| PDF-25/27 Visual | Login/setup/MFA/recovery/reauth visual UX on non-module access surfaces | Security steps, timing, non-disclosure, page-count scope. |

## 35.1 Freeze-readiness checklist

- FZ19-01 DOC-02 identity/permission model unchanged.
- FZ19-02 Frozen DOC-04 context names only.
- FZ19-03 No new Admin/public Page ID or product capability.
- FZ19-04 No DOC-08 table/column added.
- FZ19-05 Argon2id/password rules approved.

- FZ19-06 MFA/TOTP/recovery rules approved.
- FZ19-07 Session cookie/expiry/rotation rules approved.
- FZ19-08 Next-request authorization freshness proven.
- FZ19-09 Step-up L1/L2/L3 matrix approved.
- FZ19-10 Preview handoff credential lifecycle approved.
- FZ19-11 CSRF/CORS/security header baseline approved.
- FZ19-12 DOC-15 transport ceilings not relaxed.
- FZ19-13 Upload security preserves DOC-17.
- FZ19-14 Worker/service-secret rules preserve DOC-18.
- FZ19-15 Audit event dictionary mapped to existing actions.
- FZ19-16 Audit details/privacy/retention rules approved.
- FZ19-17 Incident/recovery procedures contain no hidden bypass.
- FZ19-18 Secrets are external and rotation-capable.
- FZ19-19 QA19 acceptance baseline passes.
- FZ19-20 GAP19-API-01 is resolved by DOC-15 RC7; the 11 API15-AUTH-* transport homes are verified against Section 32.1 before formal freeze.

**FREEZE STATUS**

DOC-19 RC2 has reconciled the former GAP19-API-01 against DOC-15 RC7. No known blocking upstream contradiction remains within the DOC-19 security-mechanics scope. This document remains a REVIEW CANDIDATE until explicit approval/freeze; no security algorithm or product scope was redesigned in RC2.

# A. Authentication / Token / Session Matrix

| Artifact | Entropy / factor | TTL | Single-use? | Binding / storage |
|---|---|---|---|---|
| Invite setup token | 256-bit random | 48 h | Yes | admin_id + purpose; hash only |
| Password reset token | 256-bit random | 30 min | Yes | admin_id + purpose; hash only |
| Pre-auth MFA challenge | 256-bit random ID | 5 min | Terminal after success/limit | admin_id + password-auth time |
| Admin session | 256-bit random bearer | 30m idle / 12h abs | No, revocable | admin_id; bearer hash only |
| CSRF token | 256-bit random per session | Session | Rotates with session | session-bound secret/hash |
| TOTP | 160-bit secret, 6 digits / 30s | Until replaced | Code step cannot replay | encrypted secret + last step |
| Recovery code | >=128-bit each; 10 codes | Until used/regenerated | Yes | keyed hash only |
| Step-up L1 | Password fresh proof | 10 min | Session-bound | admin_id + session + level |
| Step-up L2 | Password + MFA | 5 min | Session-bound | admin_id + session + level |
| Preview handoff | 256-bit random | 60 s | Yes | site_id + post_id + snapshot/admin; hash |
| Preview session | 256-bit random bearer | 10 min abs | No, revocable | host + site + post; bearer hash |

# B. Canonical Audit Event-Code Registry

| Family | event_code | Meaning rule |
|---|---|---|
| AUTH | AUTH.LOGIN.SUCCESS | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.LOGIN.FAILURE | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.LOGOUT | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.SESSION.EXPIRED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.SESSION.REVOKED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.STEPUP.SUCCESS | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.STEPUP.FAILURE | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.PASSWORD.SET | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.PASSWORD.CHANGED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.RESET.REQUESTED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.RESET.COMPLETED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.MFA.ENROLLED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.MFA.DISABLED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.MFA.RECOVERY_USED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.MFA.FAILURE | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.INVITE.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.INVITE.REISSUED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.INVITE.ACCEPTED | Existing action/security outcome only; details follow Sections 22-23. |
| AUTH | AUTH.INVITE.REVOKED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ACCOUNT.PROFILE.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ACCOUNT.ENABLED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ACCOUNT.DISABLED | Existing action/security outcome only; details follow Sections 22-23. |

| Family | event_code | Meaning rule |
|---|---|---|
| ACCOUNT/AUTHZ | AUTHZ.SITE_ASSIGNED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | AUTHZ.SITE_UNASSIGNED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | AUTHZ.SITE_ROLE_ASSIGNED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | AUTHZ.SITE_ROLE_UNASSIGNED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | AUTHZ.GLOBAL_ROLE_ASSIGNED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | AUTHZ.GLOBAL_ROLE_UNASSIGNED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ROLE.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ROLE.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ROLE.RETIRED | Existing action/security outcome only; details follow Sections 22-23. |
| ACCOUNT/AUTHZ | ROLE.DUPLICATED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.PUBLISHED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.SCHEDULED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.RESCHEDULED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.UNSCHEDULED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.ARCHIVED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.TRASHED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.RESTORED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.PERMANENTLY_DELETED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.DUPLICATED | Existing action/security outcome only; details follow Sections 22-23. |
| POST | POST.REVISION_RESTORED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | CATEGORY.CREATED | Existing action/security outcome only; details follow Sections 22-23. |

| Family | event_code | Meaning rule |
|---|---|---|
| CONTENT | CATEGORY.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | CATEGORY.DELETED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | TAG.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | TAG.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | TAG.MERGED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | TAG.DELETED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | AUTHOR.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | AUTHOR.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | AUTHOR.RETIRED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | MEDIA.UPLOADED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | MEDIA.METADATA_UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | MEDIA.REPLACED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | MEDIA.DELETED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | NAVIGATION.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | HOMEPAGE.CONTROL_UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | SEO.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | REDIRECT.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | REDIRECT.UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | REDIRECT.DELETED | Existing action/security outcome only; details follow Sections 22-23. |
| CONTENT | SEARCH.REINDEX_REQUESTED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | SITE.CREATED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | SITE.ENABLED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | SITE.DISABLED | Existing action/security outcome only; details follow Sections 22-23. |

| Family | event_code | Meaning rule |
|---|---|---|
| GLOBAL | SITE.ARCHIVED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | SITE.DELETION_REQUESTED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | SITE.DOMAIN_CHANGED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | PLATFORM.SETTING_UPDATED | Existing action/security outcome only; details follow Sections 22-23. |
| GLOBAL | AUDIT.EXPORTED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.CSRF.REJECT | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.CORS.REJECT | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.RATE_LIMIT | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.CROSS_SITE.DENIED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.PRIVILEGE_ESCALATION.DENIED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.PREVIEW.DENIED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.UPLOAD.REJECTED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.SECRET.ROTATED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.RECOVERY.INITIATED | Existing action/security outcome only; details follow Sections 22-23. |
| SEC | SEC.RECOVERY.COMPLETED | Existing action/security outcome only; details follow Sections 22-23. |

# C. High-Risk / Step-Up Quick Matrix

| Risk example | Level | Proof | Freshness |
|---|---|---|---|
| Site Post/media/taxonomy/redirect permanent delete | L1 | Password; plus MFA when enrolled | <=10 min |
| Site lifecycle/domain, Admin disable/site assignment, roles, Platform Settings | L2 | Password + MFA | <=5 min |
| Super Admin recovery/transfer | L3 | Mandatory MFA + controlled external recovery verification | single operation / <=5 min |
| Ordinary standard operation | L0 | Valid Admin session only | session expiry |

# D. Security Header and Browser-Control Baseline

| Surface | Required baseline |
|---|---|
| Admin | HTTPS; HSTS; CSP nonce/no unsafe-eval; object-src none; frame-ancestors none; nosniff; Referrer-Policy same-origin; Permissions-Policy deny unused capabilities; no-store; Secure HttpOnly SameSite=Lax host-only session cookie. |
| Preview | All Admin-grade passive protections applicable to public host; frame-ancestors none; Referrer-Policy no-referrer; no-store; host/site/post-bound Preview cookie; no analytics credential propagation. |
| Ordinary public | HTTPS canonical routing; HSTS; CSP allowlists per site deployment; nosniff; strict-origin-when-cross-origin; no Admin/session secrets; public cache policy remains DOC-17/18 authority. |

# E. One-Page Developer Execution Reference

| Question | Locked answer |
|---|---|
| Who defines account states/permissions? | DOC-02. DOC-19 does not add one. |
| Password hashing? | Argon2id 64 MiB, t=3, p=1, 16-byte salt, 32-byte output. |
| Super Admin MFA? | Mandatory. TOTP 6-digit/30s; recovery codes one-time. |
| Admin session? | Opaque 256-bit bearer, server-side; 30m idle / 12h absolute; `__Host-bp_admin_session`. |
| Permissions cached in session? | No long-lived authoritative snapshot; next protected request sees current state. |
| CSRF? | Session-bound 256-bit token in `X-CSRF-Token` + exact Origin for unsafe cookie-authenticated Admin requests. |
| CORS? | Credentialed Admin only from exact allowlisted origins; never wildcard. |
| Step-up? | L1 password <=10m; L2 password+MFA <=5m; L3 owner recovery single-operation. |
| Preview secret in PageData? | Never. One-time 60s handoff -> 10m host/site/post-bound Preview session -> clean URL. |
| Can original media expose EXIF? | No; DOC-17 private original remains private; public sanitized baseline only. |
| Secrets location? | External secrets manager/security store, not source/platform_settings/site_settings/public client. |
| Audit store? | DOC-08 audit_events append-only; DOC-19 supplies stable event_code and privacy-safe details. |
| Audit retention? | 365-day online minimum; raw IP security telemetry <=30 days default. |
| Public consent feature? | Not invented. Core sets no non-essential analytics/marketing cookies without approved consent mechanism. |
| Worker credentials? | Dedicated least-privilege; no user/session/Preview tokens in jobs. |

| Question | Locked answer |
|---|---|
| Known blocker? | None from the RC1 audit: GAP19-API-01 is resolved by DOC-15 RC7 and verified in Section 32.1. |
| Freeze? | Technically freeze-ready after RC7 reconciliation, pending all QA19 checks and explicit approval. |